

Έλεγχος Ευπαθειών TLS

Εισαγωγή

Το πρωτόκολλο **Transport Layer Security - TLS**¹ αποτελεί ίσως το πιο κλασικό πρωτόκολλο ασφάλειας δικτύου, εγκαθιδρύοντας ασφαλείας συνδέσεις μεταξύ ενός client και ενός server, με τις ακόλουθες υπηρεσίες ασφαλείας:

- 1) **Εμπιστευτικότητα** της πληροφορίας που μεταδίδεται, μέσω συμμετρικής κρυπτογράφησης
- 2) **Ακεραιότητα** της πληροφορίας που μεταδίδεται, μέσω τεχνικών αυθεντικοποίησης (οπότε και αναφερόμαστε τελικά σε «αυθεντικοποιημένη κρυπτογράφηση»)
- 3) **Πιστοποίηση** της ταυτότητας του server (και, προαιρετικά, και του client) μέσω ψηφιακών πιστοποιητικών (μπορείτε να ανακαλέσετε την Εργασία 1). Το δημόσιο κλειδί που αναγράφεται στο ψηφιακό πιστοποιητικό του server αξιοποιείται για την ασφαλή ανταλλαγή των κλειδιών που απαιτούνται για την αυθεντικοποιημένη κρυπτογράφηση.

Στο Διαδίκτυο, για ασφαλή πρόσβαση σε **http** ιστοσελίδες υλοποιείται σε υποκείμενο στρώμα δικτύου το πρωτόκολλο TLS, οπότε και έχουμε τελικά το πρωτόκολλο **https**.

Η πλέον πρόσφατη έκδοση του πρωτοκόλλου είναι το **TLS 1.3**². Ωστόσο, εξακολουθούν να υπάρχουν και παλαιότερες εκδόσεις – κάποιες εκ των οποίων, αν υλοποιηθούν με όχι σωστές ρυθμίσεις, γεννάνε ζητήματα ασφαλείας. Τέτοια παραδείγματα είναι τα εξής:

- Πολλές εκδόσεις του πρωτοκόλλου, συμπεριλαμβανομένης και της προηγούμενης **TLS 1.2**³, υποστηρίζουν, μεταξύ άλλων, ασθενείς κρυπτογραφικούς αλγορίθμους (κρυπτογραφικές σουίτες) – π.χ. τον συμμετρικό αλγόριθμο RC4 (που δεν θεωρείται ασφαλής), τον ασύμμετρο αλγόριθμο Diffie-Hellman ή/και τον RSA χωρίς ασφαλή μεγέθη κλειδιών κ.α.
- Πολλές εκδόσεις, ιδίως από την **TLS 1.1**⁴ και προηγούμενες (οι οποίες ονομάζονται SSL 1, SSL 2, SSL 3) έχουν εγγενείς σχεδιαστικές αδυναμίες (π.χ. τα padding bits στους κρυπτογραφικούς αλγορίθμους δεν συμπεριλαμβάνονται στα δεδομένα που αυθεντικοποιούνται, το οποίο μπορεί να οδηγήσει σε αποτελεσματικές επιθέσεις όπως η επίθεση **POODLE**⁵).

¹ <https://hpbn.co/transport-layer-security-tls/>

² <https://datatracker.ietf.org/doc/html/rfc8446>

³ <https://datatracker.ietf.org/doc/html/rfc5246>

⁴ <https://datatracker.ietf.org/doc/html/rfc4346>

⁵ <https://www.techtarget.com/whatis/definition/POODLE-attack>

- Ακόμα και αν ένας server υποστηρίζει την πλέον πρόσφατη έκδοση του πρωτοκόλλου, γεννώνται ζητήματα εφόσον υποστηρίζει ταυτόχρονα – προς χάριν, π.χ., εξυπηρέτησης χρηστών που χρησιμοποιούν παλαιούς browser – παλαιότερες εκδόσεις. Χαρακτηριστική είναι η περίπτωση της επίθεσης **DROWN**⁶, η οποία επιτρέπει την ανάκτηση κρυπτογραφημένης πληροφορίας που έχει ανταλλαγή με ασφαλή έκδοση του πρωτοκόλλου, απλά και μόνο επειδή ο server υποστηρίζει ταυτόχρονα και παλαιότερες ανασφαλείς εκδόσεις (και έχει το ίδιο πιστοποιητικό με αυτές).

Εργαλεία ελέγχου ευπαθειών TLS (TLS Scanning)

Υπάρχουν διαθέσιμα εργαλεία που εξετάζουν ιστοσελίδες ως προς το πόσο σωστά υλοποιημένο είναι το πρωτόκολλο TLS, αναγνωρίζοντας ευπάθειες. Πολλά εργαλεία εκτελούνται μέσω εγκατάστασής τους σε υπολογιστή (βλ., π.χ. <https://linuxsecurity.expert/security-tools/ssltls-scanners>), ενώ άλλα είναι διαθέσιμα web εργαλεία και δεν απαιτούν καμία εγκατάσταση (π.χ. <https://www.ssllabs.com/ssltest/>, <https://hackertarget.com/ssl-check/> - στη δεύτερη ιστοσελίδα παρατίθεται και μία σύντομη περιγραφή γνωστών ευπαθειών των υλοποιήσεων TLS, τις οποίες εξετάζουν αυτά τα εργαλεία, και η οποία θα σας βοηθήσει στην εξήγηση των αποτελεσμάτων που θα λάβετε).

Περιβάλλον εργαστηρίου

Η άσκηση αυτή μπορεί να εκτελεστεί **και εκτός** της εικονικής μηχανής **SEEDUbuntu - Ubuntu 16.04**, χρησιμοποιώντας οποιαδήποτε εγκατάσταση **Linux**. Για την εκτέλεση της άσκησης απαιτείται μόνο η εγκατάσταση των εργαλείων **ssltls scanners** και η χρήση ενός **web browser**.

⁶ <https://drownattack.com>

Δραστηριότητα 1: TLS Scanning σε ηλεκτρονικά καταστήματα

Ο στόχος αυτής της δραστηριότητας είναι ο έλεγχος εφαρμογών e-shop για ευπάθειες που σχετίζονται με το πρωτόκολλο TLS.

Κάνοντας χρήση **δύο διαφορετικών εργαλείων** για **TLS scanning** (οποιοδήποτε τύπου, της επιλογής σας), ελέγξτε έναν διαδικτυακό τόπο της επιλογής σας που να αφορά ηλεκτρονικό κατάστημα (e-shop).

Να παραθέσετε τις αναφορές (reports) και από τα δύο εργαλεία, να δείτε αν τα εργαλεία «συμφωνούν» στα ευρήματά τους (σχολιάζοντας σχετικά αν το ένα πραγματοποιεί, π.χ. εκτενέστερους ελέγχους, και να σχολιάσετε με δικά σας λόγια τη συνολική ασφάλεια του ιστοτόπου. Για ευπάθειες που ενδεχομένως βρεθούν, θα χρειαστεί να αναζητήσετε πληροφορίες ως προς τι ακριβώς αφορούν – οπότε και, στην περίπτωση αυτή, θα πρέπει να παραθέσετε τις πηγές σας.

Στην αναφορά σας, εκτός από την περιγραφή των επιλογών σας (εργαλεία, διαδικτυακό κατάστημα), θα πρέπει να παραθέσετε τις αναφορές (reports) και από τα δύο εργαλεία, να δείτε αν τα εργαλεία «συμφωνούν» στα ευρήματά τους (σχολιάζοντας σχετικά αν το ένα πραγματοποιεί, π.χ. εκτενέστερους ελέγχους), και να σχολιάσετε με δικά σας λόγια τη συνολική ασφάλεια του ιστοτόπου.

Για ευπάθειες που ενδεχομένως βρεθούν, θα χρειαστεί να αναζητήσετε πληροφορίες ως προς τι ακριβώς αφορούν – οπότε και, στην περίπτωση αυτή, θα πρέπει να παραθέσετε τις πηγές σας.

Δραστηριότητα 2: TLS Scanning σε ειδησεογραφικά sites

Ομοίως με τη Δραστηριότητα 1, αλλά αυτή τη φορά θα ελέγξετε ένα **ειδησεογραφικό site** της επιλογής σας.

Δραστηριότητα 3: TLS Scanning σε sites Πανεπιστημίων

Ομοίως με τη Δραστηριότητα 1, αλλά αυτή τη φορά θα ελέγξετε έναν ιστοτόπο **Πανεπιστημίου** της επιλογής σας.

Δραστηριότητα 4: TLS Scanning ύποπτης ιστοσελίδας

Κάποιοι χρήστες του οργανισμού σας, στον οποίο εργάζεστε ως **Υπεύθυνος Ασφάλειας Δικτύων**, σας ενημέρωσαν ότι φαίνεται να έγινε διαρροή προσωπικών τους δεδομένων στο

ίδιο χρονικό διάστημα. Μελετώντας τις διαδικτυακές τους κινήσεις, προέκυψε ότι όλοι οι εν λόγω χρήστες είχαν επισκεφτεί την ιστοσελίδα <https://www.blackboxresale.com/login.aspx>. Σχολιάστε αν είναι πιθανό, κατά τη γνώμη σας, η διαρροή να προέρχεται από αυτήν την ιστοσελίδα. Αναπτύξτε σκεπτικό, με βάση τα ευρήματά σας από **έλεγχο ευπαθειών** του TLS της συγκεκριμένης ιστοσελίδας.

Υποβολή

Θα πρέπει να υποβάλετε μια λεπτομερή **εργαστηριακή αναφορά** (σε PDF) που θα καλύπτει όλες τις ενέργειες που κάνατε σε κάθε δραστηριότητα, τα αποτελέσματα και τις παρατηρήσεις σας. Στην περιγραφή σας χρησιμοποιείτε τις αναφορές από τα εργαλεία, σύμφωνα με τις οδηγίες κάθε δραστηριότητας.